

Security Scan Executive Summary

Project: Authorization Service

Scan Date: April 24, 2026 at 07:57

Total Findings	286
Critical	15
High	89
Medium	116
Low	66
Info	0

Security Tools Used:

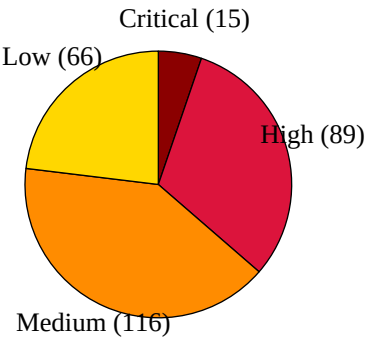
SpotBugs, PMD, Snyk, OWASP Dependency-Check, Trivy Filesystem, Trivy Image

Executive Summary

Overall Risk Level: **CRITICAL**

This application has 15 critical vulnerabilities that require immediate attention.

A comprehensive security scan was performed using 6 different security tools, identifying a total of 286 findings across various severity levels. The scan included Static Application Security Testing (SAST), dependency vulnerability scanning, and container image analysis.



Findings by Security Tool

SpotBugs (48 findings)

Severity	Count
HIGH	1
MEDIUM	24
LOW	23

PMD (7 findings)

Severity	Count
LOW	7

Snyk (87 findings)

Severity	Count
CRITICAL	7
HIGH	36

MEDIUM	31
LOW	13

OWASP Dependency-Check (6 findings)

Severity	Count
MEDIUM	5
LOW	1

Trivy Filesystem (69 findings)

Severity	Count
CRITICAL	4
HIGH	26
MEDIUM	28
LOW	11

Trivy Image (69 findings)

Severity	Count
CRITICAL	4
HIGH	26
MEDIUM	28
LOW	11

Critical & High Priority Issues

1. [CRITICAL] SNYK-JAVA-ORGAPACHETOMCATEMBED-15307781

Tool: Snyk

Description: Improper Certificate Validation

Package: org.apache.tomcat.embed:tomcat-embed-core

2. [CRITICAL] SNYK-JAVA-ORGAPACHETOMCATEMBED-8383920

Tool: Snyk

Description: Uncaught Exception

Package: org.apache.tomcat.embed:tomcat-embed-core

3. [CRITICAL] SNYK-JAVA-ORGAPACHETOMCATEMBED-8523186

Tool: Snyk

Description: Time-of-check Time-of-use (TOCTOU) Race Condition

Package: org.apache.tomcat.embed:tomcat-embed-core

4. [CRITICAL] SNYK-JAVA-ORGAPACHETOMCATEMBED-8547999

Tool: Snyk

Description: Time-of-check Time-of-use (TOCTOU) Race Condition

Package: org.apache.tomcat.embed:tomcat-embed-core

5. [CRITICAL] SNYK-JAVA-ORGSPRINGFRAMEWORKSECURITY-15701796

Tool: Snyk

Description: Use of Cache Containing Sensitive Information

Package: org.springframework.security:spring-security-web

6. [CRITICAL] SNYK-JAVA-ORGSPRINGFRAMEWORKSECURITY-8309135

Tool: Snyk

Description: Missing Authorization

Package: org.springframework.security:spring-security-web

7. [CRITICAL] SNYK-JAVA-ORGSPRINGFRAMEWORKSECURITY-9486467

Tool: Snyk

Description: Authentication Bypass by Primary Weakness

Package: org.springframework.security:spring-security-crypto

8. [CRITICAL] CVE-2025-24813

Tool: Trivy (Filesystem)

Description: tomcat: Potential RCE and/or information disclosure and/or information corruption with partial PUT

Package: org.apache.tomcat.embed:tomcat-embed-core

9. [CRITICAL] CVE-2026-29145

Tool: Trivy (Filesystem)

Description: Apache Tomcat: Apache Tomcat: Authentication bypass due to CLIENT_CERT soft fail misconfiguration

Package: org.apache.tomcat.embed:tomcat-embed-core

10. [CRITICAL] CVE-2024-38821

Tool: Trivy (Filesystem)

Description: Spring-WebFlux: Authorization Bypass of Static Resources in WebFlux Applications

Package: org.springframework.security:spring-security-web

11. [CRITICAL] CVE-2026-22732

Tool: Trivy (Filesystem)

Description: Spring Security: Spring Security: Security policy bypass and information disclosure due to unwritten HTTP headers

Package: org.springframework.security:spring-security-web

12. [CRITICAL] CVE-2025-24813

Tool: Trivy (Image)

Description: tomcat: Potential RCE and/or information disclosure and/or information corruption with partial PUT

Package: org.apache.tomcat.embed:tomcat-embed-core

13. [CRITICAL] CVE-2026-29145

Tool: Trivy (Image)

Description: Apache Tomcat: Apache Tomcat: Authentication bypass due to CLIENT_CERT soft fail misconfiguration

Package: org.apache.tomcat.embed:tomcat-embed-core

14. [CRITICAL] CVE-2024-38821

Tool: Trivy (Image)

Description: Spring-WebFlux: Authorization Bypass of Static Resources in WebFlux Applications

Package: org.springframework.security:spring-security-web

15. [CRITICAL] CVE-2026-22732

Tool: Trivy (Image)

Description: Spring Security: Spring Security: Security policy bypass and information disclosure due to unwritten HTTP headers

Package: org.springframework.security:spring-security-web

16. [HIGH] HE_EQUALS_USE_HASHCODE

Tool: SpotBugs

Description: com.pkn.authservice.security.UserDetailsImpl defines equals and uses Object.hashCode()

File: com/pkn/authservice/security/UserDetailsImpl.java (Line 17)

17. [HIGH] SNYK-JAVA-COMFASTERXMLJACKSONCORE-15365924

Tool: Snyk

Description: Allocation of Resources Without Limits or Throttling

Package: com.fasterxml.jackson.core:jackson-core

18. [HIGH] SNYK-JAVA-COMFASTERXMLJACKSONCORE-15907551

Tool: Snyk

Description: Allocation of Resources Without Limits or Throttling

Package: com.fasterxml.jackson.core:jackson-core

19. [HIGH] SNYK-JAVA-COMMONSFILEUPLOAD-10363252

Tool: Snyk

Description: Allocation of Resources Without Limits or Throttling

Package: commons-fileupload:commons-fileupload

20. [HIGH] SNYK-JAVA-COMMONSLANG-10734077

Tool: Snyk

Description: Uncontrolled Recursion

Package: commons-lang:commons-lang

Note: Showing top 20 of 104 critical/high issues. See full JSON report for complete details.

Recommendations & Next Steps

- 1. Address Critical Vulnerabilities:** Immediately remediate 15 critical vulnerabilities. These pose the highest risk to the application.
- 2. Fix High-Severity Issues:** Prioritize fixing 89 high-severity vulnerabilities within the next sprint.
- 3. Review Medium-Severity Findings:** Evaluate 116 medium-severity issues and plan remediation based on risk assessment.
- 4. Implement Continuous Scanning:** Integrate these security scans into your CI/CD pipeline to catch vulnerabilities early in the development process.
- 5. Regular Updates:** Keep all dependencies and base images up to date to minimize exposure to known vulnerabilities.
- 6. Security Training:** Provide security awareness training to development teams to prevent common vulnerabilities.